

OPEN-SOURCE INTELLIGENCE EXERCISES

Ana Šinik, SV11/2022
Filip Tot, SV14/2022
Lazar Nagulov, SV61/2022

1. Pixel Perfect

task.txt:

Flag format : UNS{}

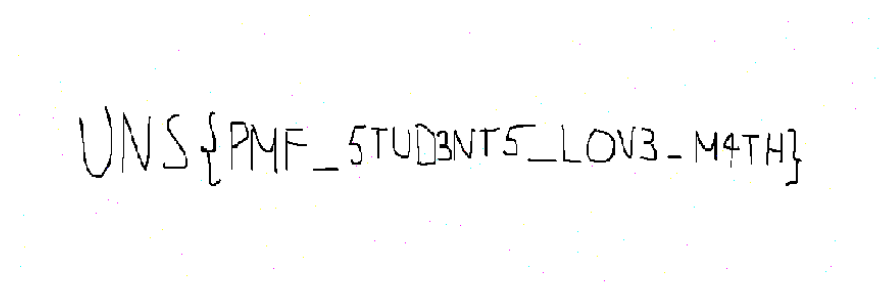
Your college mate likes to take photos in his spare time. He recently sent you a picture of him and said he had something very important to tell you. Since then, there is no trace of him. Maybe you should take a closer look at the picture?

sus.png:



Rešenje:

U task.txt piše kako je fotografiju potrebno bolje pogledati. To je dalo znak da je u pitanju steganografija. Koristila sam online alat [aperisolve.com](https://www.aperisolve.com) za steganografsku analizu, koji je otkrio skrivenu poruku i dao flag: **UNS{PMF_5TUD3NT5_LOV3_M4TH}**



2. Squid Game Invitation

task.txt:

Flag format : NAVY{ }

image.jpg:



Rešenje:

Data je fotografija pozivnice sa simbolima i email adresom squidgameph1337@gmail.com. AI je predložio slanje email-a na tu adresu. Bila sam skeptična sa tim pristupom, ali zbog nedostatka ideja sam pokušala. Nije bilo odgovora. Onda sam shvatila sa korisnici često koriste isti username na više platformi pa pretrazila squidgameph1337 na instagramu i githubu. Nalog je pronađen na githubu. Ušla sam u pinovani repo squidgame. U [poslednjem commitu](#) je vrijednost traženog flaga: **NAVY{h4v3_you_3v3r_w4tched_!t?}**

```
Commit fda0250
squidgameph1337 authored on Oct 17, 2021 [Verified]

Update index.html
main
1 file changed
+1 -1

index.html
17 </div>
18 <div class="back">
19 <div class="icon"></div>
20 <div class="phone-number">h4v3_you_3v3r_w4tched_!t?</div>
21 </div>
22 </div>
23 <!-- partial -->

17 </div>
18 <div class="back">
19 <div class="icon"></div>
20 <div class="phone-number">NAVY{h4v3_you_3v3r_w4tched_!t?}</div>
21 </div>
22 </div>
23 <!-- partial -->
```

3. Commitment

task.txt:

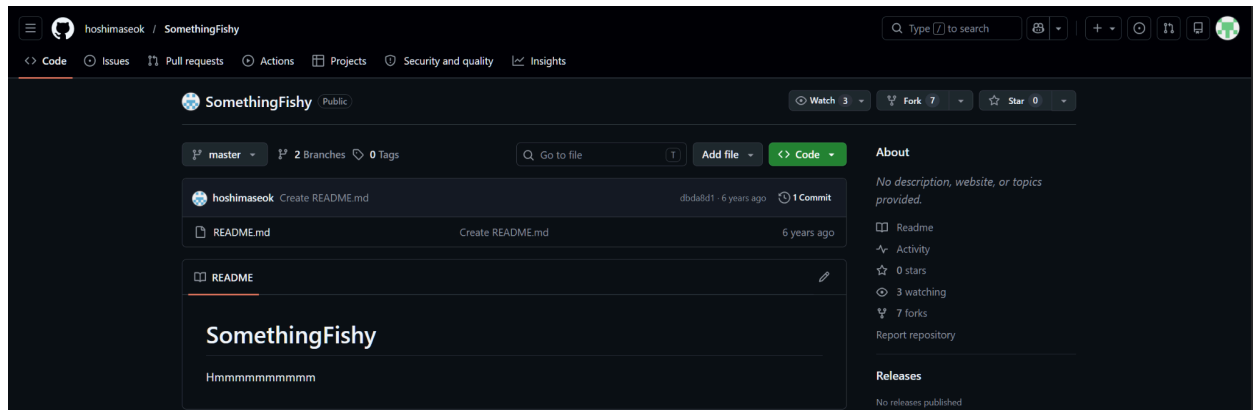
Flag format : csictf{ }

hoshimaseok is up to no good. Track him down.

Rešenje:

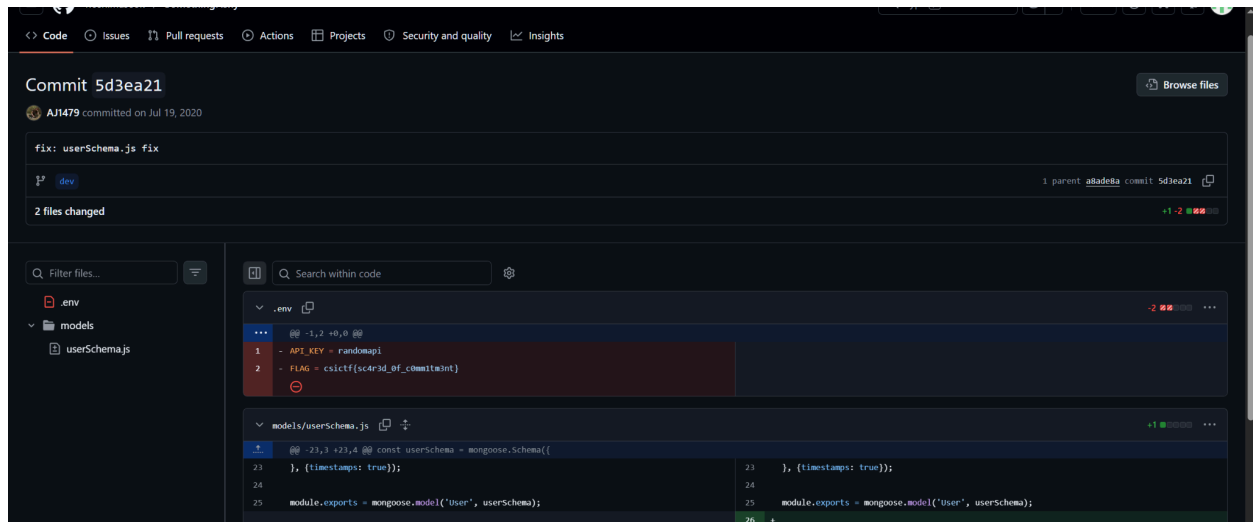
U task.txt dato je korisničko ime hoshimaseok. Iz samog imena zadatka pretpostavio sam da je potrebno proveriti komitove na github nalogu sa datim korisničkim imenom.

Nakon što sam pronašao github nalog, ušao sam u repository “SomethingFishy”.



Pretraživao sam komitove na dev grani sve dok nisam naišao na traženi flag:

csictf{sc4r3d_of_comm1tm3nt}.



4. Nigerian Prince

task.txt:

Flag format : UNS{ }

Your friend received a very strange email. Since he knows you understand computers, he sent you the email's content and asked you to check if that email has any meaning or it's just another spam?

email.txt:

Dear Friend ; Thank-you for your interest in our newsletter
! If you no longer wish to receive our publications
simply reply with a Subject: of "REMOVE" and you will
immediately be removed from our mailing list . This
mail is being sent in compliance with Senate bill 1622
, Title 8 ; Section 308 . THIS IS NOT MULTI-LEVEL MARKETING
! Why work for somebody else when you can become rich
in 23 WEEKS . Have you ever noticed most everyone has
a cellphone and more people than ever are surfing the
web ! Well, now is your chance to capitalize on this
! We will help you turn your business into an E-BUSINESS
& increase customer response by 140% ! You are guaranteed
to succeed because we take all the risk ! But don't
believe us ! Mrs Jones who resides in Connecticut tried
us and says "My only problem now is where to park all
my cars" ! We are a BBB member in good standing . We
BESEECH you - act now . Sign up a friend and you get
half off ! Thank-you for your serious consideration
of our offer . Dear Internet user ; This letter was
specially selected to be sent to you . This is a one
time mailing there is no need to request removal if
you won't want any more . This mail is being sent in
compliance with Senate bill 1916 , Title 1 ; Section
305 ! THIS IS NOT A GET RICH SCHEME ! Why work for
somebody else when you can become rich in 81 days !
Have you ever noticed people love convenience and how
long the line-ups are at bank machines . Well, now
is your chance to capitalize on this ! WE will help
YOU turn your business into an E-BUSINESS plus turn
your business into an E-BUSINESS . You can begin at
absolutely no cost to you . But don't believe us !
Prof Jones of Indiana tried us and says "I was skeptical
but it worked for me" ! This offer is 100% legal !
Because the Internet operates on "Internet time" you
must hurry ! Sign up a friend and you'll get a discount

of 50% . Thank-you for your serious consideration of our offer .

Rešenje:

Iz same postavke zadatke, pretpostavio sam da se radi o steganografiji. Pokušao sam nekoliko tehnika skrivanja podataka u tekstu:

- prva slova svake reči,
- prva slova svake rečenice,
- razmaci između reči,
- dužine reči...

Pošto ništa od ovoga nije dovelo do rešenja, odlučio sam da pretražim više o spam email steganografiji. Pretraga me je dovela do sajta <https://www.spammimic.com/>, koji me je odmah doveo do traženog flaga: **UNS{EM4IL_5P4M_AG4N?}**.

5. Pirates of Memorial

task.txt

- Flag format : csictf{}
- The original photographer of this picture commented the flag on his post. Find the flag.

EYkH3wnXsAAAtG6j.jpeg



Rešenje:

Pomoću reverse-image search pronašao sam [twitter post](#) koji je repost-ovao traženu sliku. U komentarima posta našao sam reply originalnog autora slike:



Sledeći korak je bilo gledanje postova na instagramu autora slike i traženje originalnog post-a. Nakon duže pretrage pronašao sam originalni post i traženi flag:

csictf{pl4g14r1sm_1s_b4d}

6. Maps OSINT 2

task.txt

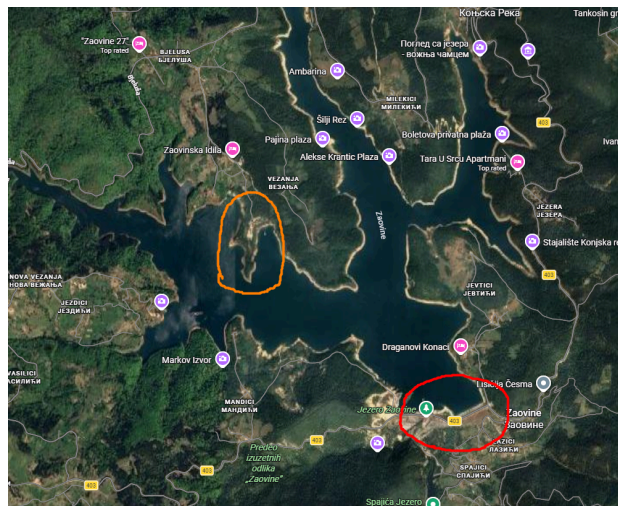
Flag Format : UNS{XX.XXXXXXXX,XX.XXXXXXXX}

image.jpg



Rešenje:

Pomoću reverse-image search pronašao sam da je jezero na slici Zaovinsko jezero. Doduše, reverse-image search nije uspevao pronaći priloženu sliku na mapama. Sledeći korak je bio pronaći tačnu lokaciju odakle je uzeta slika.



Koristio sam dva značajna obeležja jezera kako bih utvrdio tačnu lokaciju slike. Prvo možemo primetiti branu koja deli jezero i reku Beli Rzav. Označena je crvenom bojom na obe slike. Drugi trag predstavlja poluostvro unikatnog oblika koje je može lako primetiti na oba slike, označeno narandžastom bojom. Na osnovu ova dva obeležja, lako se pronalazi lokacija odakle je slika uzeta:

[Zaovine Lake - Google Maps](#)

S obzirom da je tražena lokacija slike, konačni flag je: **UNS{43.8704997,19.3853197}**

7. Sakura izazov

Background

This room is designed to test a wide variety of different OSINT techniques. With a bit of research, most beginner OSINT practitioners should be able to complete these challenges. This room will take you through a sample OSINT investigation in which you will be asked to identify a number of identifiers and other pieces of information in order to help catch a cybercriminal. Each section will include some pretext to help guide you in the right direction, as well as one or more questions that need to be answered in order to continue on with the investigation. Although all of the flags are staged, this room was created using working knowledge from having led and assisted in OSINT investigations both in the public and private sector.

NOTE: All answers can be obtained via passive OSINT techniques, DO NOT attempt any active techniques such as reaching out to account owners, password resets, etc to solve these challenges.

If you have any other questions, comments, or suggestions, please reach out to us at @OSINTDojo on Twitter.

7.1. Zadatak 1

Background

The OSINT Dojo recently found themselves the victim of a cyber attack. It seems that there is no major damage, and there does not appear to be any other significant indicators of compromise on any of our systems. However during forensic analysis our admins found an image left behind by the cybercriminals. Perhaps it contains some clues that could allow us to determine who the attackers were?

We've copied the image left by the attacker, you can view it in your browser [here](#).

Instructions

Images can contain a treasure trove of information, both on the surface as well as embedded within the file itself. You might find information such as when a photo was created, what software was used, author and copyright information, as well as other metadata significant to an investigation. In order to answer the following question, you will need to thoroughly analyze the image found by the OSINT Dojo administrators in order to obtain basic information on the attacker.

Rešenje:

Data je sledeća fotografija



sa .svg ekstenzijom. Pogledali smo njene metapodatke i videli putanju u atributu svg taga koji se zove inkscape:export-filename. Vrednost tog atributa je /home/username/... gde je username = SakuraSnowAngelAiko. To je traženi odgovor.

What username does the attacker go by?

SakuraSnowAngelAiko

✓ Correct Answer

7.2. Zadatak 2

Background

It appears that our attacker made a fatal mistake in their operational security. They seem to have reused their username across other social media platforms as well. This should make it far easier for us to gather additional information on them by locating their other social media accounts.

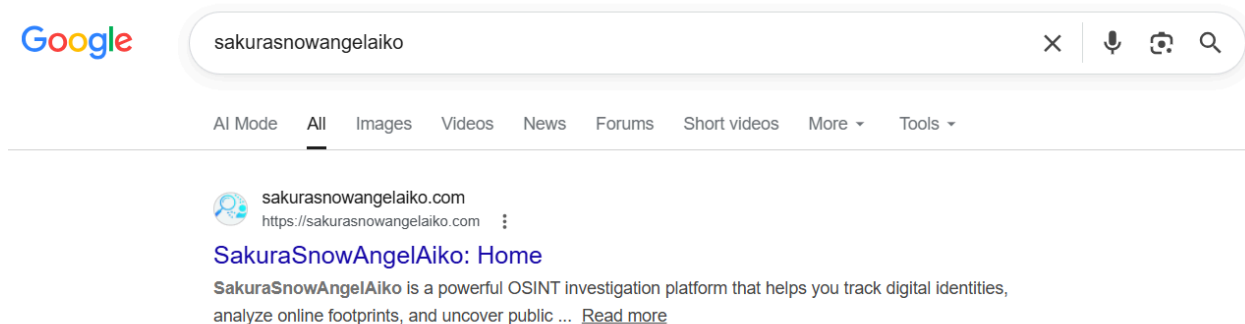
Instructions

Most digital platforms have some sort of username field. Many people become attached to their usernames, and may therefore use it across a number of platforms, making it easy to find other accounts owned by the same person when the username is unique enough. This can be especially helpful on platforms such as on job hunting sites where a user is more likely to provide real information about themselves, such as their full name or location information.

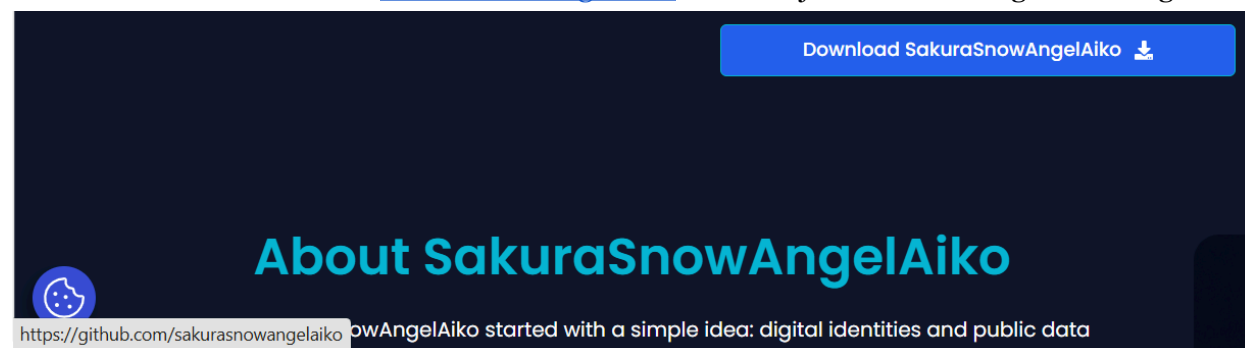
A quick search on a reputable search engine can help find matching usernames on other platforms, and there are also a large number of specialty tools that exist for that very same purpose. Keep in mind, that sometimes a platform will not show up in either the search engine results or in the specialized username searches due to false negatives. In some cases you need to manually check the site yourself to be 100% positive if the account exists or not. In order to answer the following questions, use the attacker's username found in Task 2 to expand the [OSINT](#) investigation onto other platforms in order to gather additional identifying information on the attacker. Be wary of any false positives!

Rešenje:

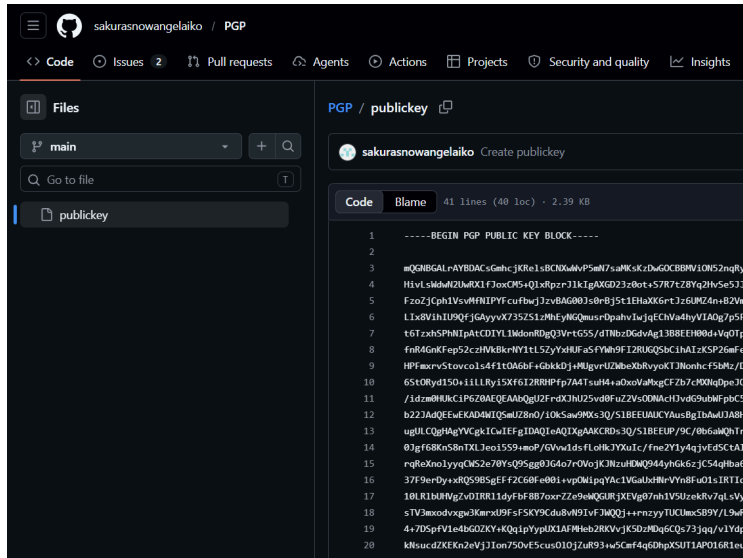
Kako smo u prethodnom zadatku saznali username, pretražili smo ga na google:



Odatle smo došli na stranicu [SakuraSnowAngelAiko](#). Preko sajta smo došli do github naloga:



Tu ima nekoliko repozitorijuma na kojima smo pokušavali naći punu email adresu. Našli smo je na [PGP](#) repo-u gde je jedini okačeni fajl publickey odakle je jednostavno saznati email.

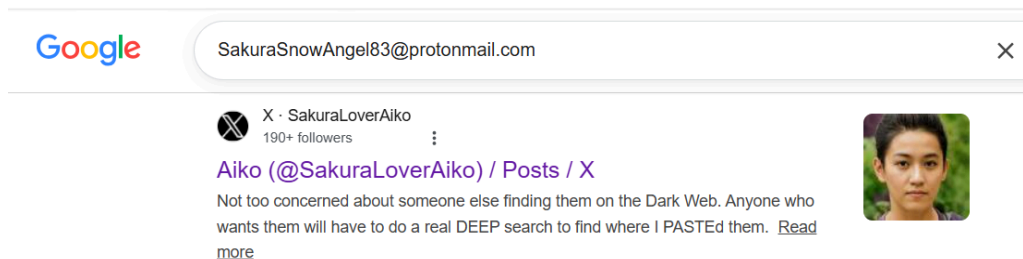


```
b4 20 53 61 6b 75 72 61 53 6e 6f 77 41 6e 67 65
6c 38 33 40 70 72 6f 74 6f 6e 6d 61 69 6c 2e 63
6f 6d
```

User ID Packet (0xd)

```
cipherTypeByte: "180"
length: "32"
userId: "SakuraSnowAngel83@protonmail.com"
```

Pretragom mejla na google-u smo došli do X naloga:



Tu je ova objava gde se attacker predstavio:



What is the full email address used by the attacker?

SakuraSnowAngel83@protonmail.com

✓ Correct Answer

What is the attacker's full real name?

Aiko Abe

✓ Correct Answer

7.3. Zadatak 3

Background

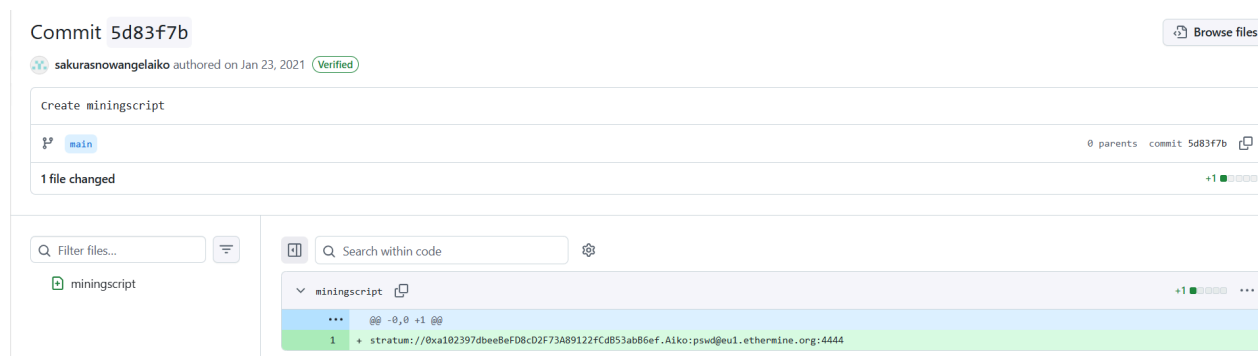
It seems the cybercriminal is aware that we are on to them. As we were investigating into their Github account we observed indicators that the account owner had already begun editing and deleting information in order to throw us off their trail. It is likely that they were removing this information because it contained some sort of data that would add to our investigation. Perhaps there is a way to retrieve the original information that they provided?

Instructions

On some platforms, the edited or removed content may be unrecoverable unless the page was cached or archived on another platform. However, other platforms may possess built-in functionality to view the history of edits, deletions, or insertions. When available this audit history allows investigators to locate information that was once included, possibly by mistake or oversight, and then removed by the user. Such content is often quite valuable in the course of an investigation. In order to answer the below questions, you will need to perform a deeper dive into the attacker's Github account for any additional information that may have been altered or removed. You will then utilize this information to trace some of the attacker's cryptocurrency transactions.

Rešenje:

Na github nalogu postoji repository "ETH". Proverom istorijom komitova pronađena je adresa kripto wallets i mining pool.



Commit 5d83f7b

sakurasnowangelaiko authored on Jan 23, 2021 (Verified)

Create miningscript

1 file changed

miningscript

```
*** @@ -0,0 +1 @@
1 + stratum://0xa102397dbee8eFD8cD2F73A89122fCdB53abB6ef.Aiko:psw@eu1.ethermine.org:4444
```

Proverom transakcije pronađena je druga kripto valuta koju je napadač koristio (Tether).

	ID: 0xde-96fd 1/23/2021, 21:30:43	From Ethermine To 0xa1-b6ef	0.05007333 ETH • \$81.93 Fee 21.0K Gwei • \$0.03
	ID: 0x65-ded9 1/19/2021, 17:35:56	From 0xa1-b6ef To Tether USDT	0.00000000 ETH • \$0.00 Fee 2.6M Gwei • \$4.29

What cryptocurrency does the attacker own a cryptocurrency wallet for?

Ethereum

✓ Correct Answer

What is the attacker's cryptocurrency wallet address?

0xa102397dbee8eFD8cD2F73A89122fCdB53abB6ef

✓ Correct Answer

What mining pool did the attacker receive payments from on January 23, 2021 UTC?

Ethermine

✓ Correct Answer

What other cryptocurrency did the attacker exchange with using their cryptocurrency wallet?

Tether

✓ Correct Answer

7.4. Zadatak 4

Background

Just as we thought, the cybercriminal is fully aware that we are gathering information about them after their attack. They were even so brazen as to message the OSINT Dojo on Twitter and taunt us for our efforts. The Twitter account which they used appears to use a different username than what we were previously tracking, maybe there is some additional information we can locate to get an idea of where they are heading to next?

We've taken a screenshot of the message sent to us by the attacker, you can view it in your browser [here](#).

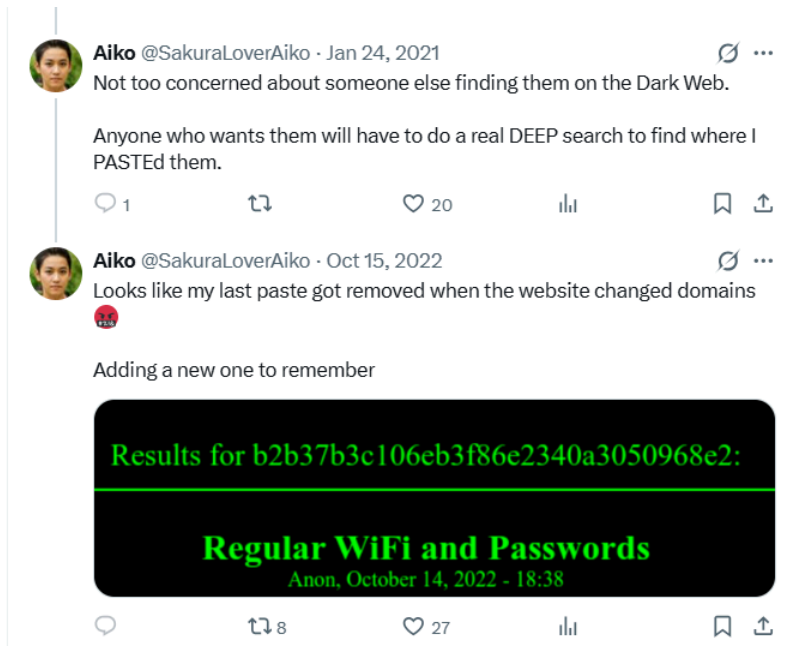
Instructions

Although many users share their username across different platforms, it isn't uncommon for users to also have alternative accounts that they keep entirely separate, such as for investigations, trolling, or just as a way to separate their personal and public lives. These alternative accounts might contain information not seen in their other accounts, and should also be investigated thoroughly. In order to answer the following questions, you will need to view the screenshot of the message sent by the attacker to the OSINT Dojo on Twitter and use it to locate additional information on the attacker's Twitter account. You will then need to follow the leads from the Twitter account to the Dark Web and other platforms in order to discover additional information.

Rešenje:

Možemo primetiti da X nalog referenciran u zadatku 2 ima handle @SakuraLoveAiko i da se napadač predstavlja kao @AikoAbe3. S obzirom da to nije više njihov handle, zaključujemo da je korisnik promenio svoj username i handle kako bi izbegao potragu i da je traženi novi handle @SakuraLoveAiko.

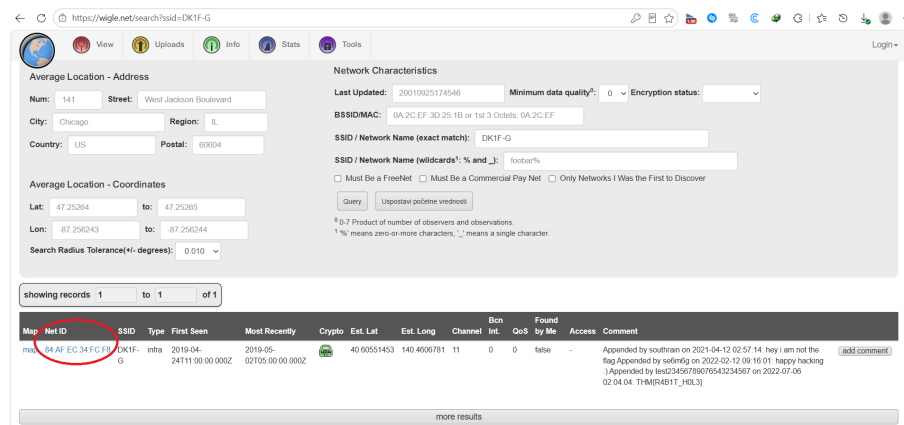
Pregledom postova na novom X nalogu napadača pronađena su dva posta koji otkrivaju dalje korake:



Prvi post ukazuje na dark web pastebin stranicu DeepPaste. Odlaskom na tu stranicu i pretragom id-a paste-a (b2b37b3c106eb3f86e2340a3050968e2) može se naći sledeći sadržaj:



Primetimo SSID ličnog rutera napadača DK1F-G. Da bismo pronašli BSSID rutera treba nam sajt za takvu pretragu. Jedna opcija je <https://wifig.net>. Pretragom po SSID-u nalazimo ID mreže koji je tražen u zadatku:



What is the attacker's current Twitter handle?

SakuraLoverAiko

✓ Correct Answer

What is the BSSID for the attacker's Home WiFi?

84:af:ec:34:fc:f8

✓ Correct Answer



7.5. Zadatak 5

Background

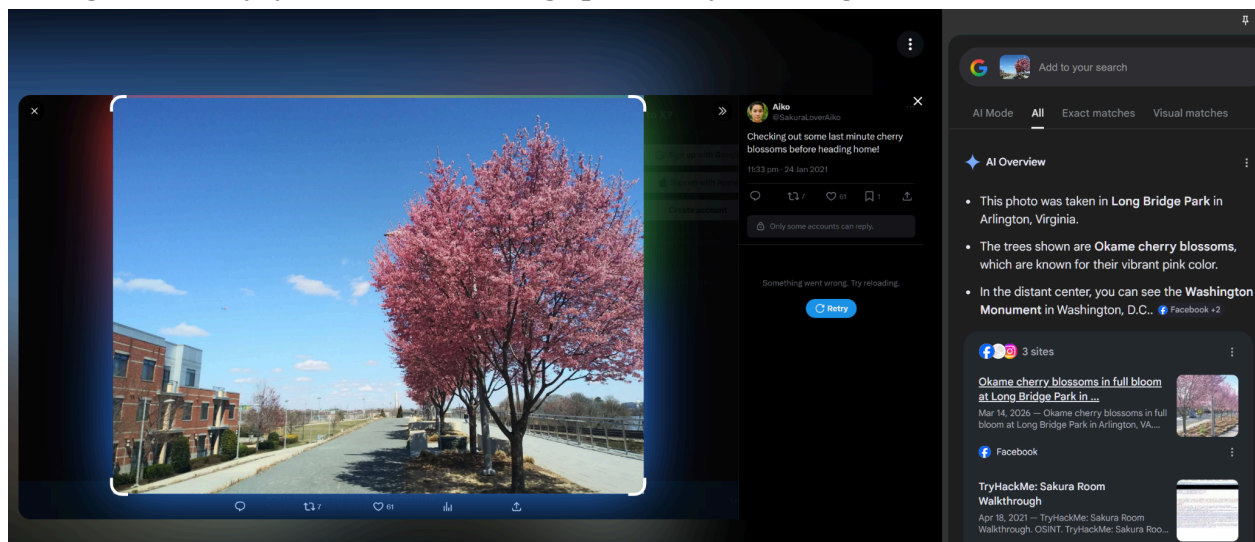
Based on their tweets, it appears our cybercriminal is indeed heading home as they claimed. Their Twitter account seems to have plenty of photos which should allow us to piece together their route back home. If we follow the trail of breadcrumbs they left behind, we should be able to track their movements from one location to the next back all the way to their final destination. Once we can identify their final stops, we can identify which law enforcement organization we should forward our findings to.

Instructions

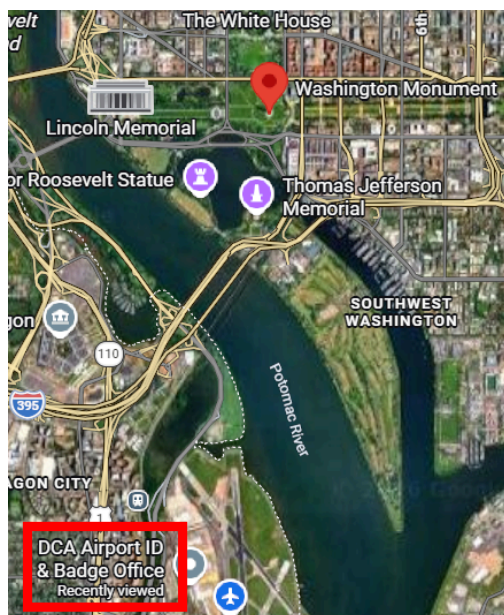
In OSINT, there is oftentimes no "smoking gun" that points to a clear and definitive answer. Instead, an OSINT analyst must learn to synthesize multiple pieces of intelligence in order to make a conclusion of what is likely, unlikely, or possible. By leveraging all available data, an analyst can make more informed decisions and perhaps even minimize the size of data gaps. In order to answer the following questions, use the information collected from the attacker's Twitter account, as well as information obtained from previous parts of the investigation to track the attacker back to the place they call home.

Rešenje:

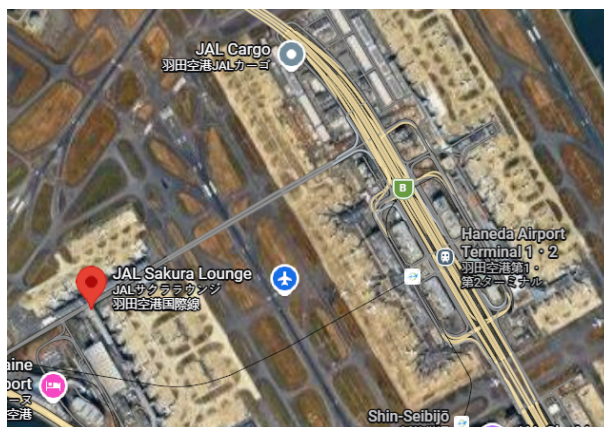
Pretragom slike koja je okačena na X nalogu primećen je Washington Monument.



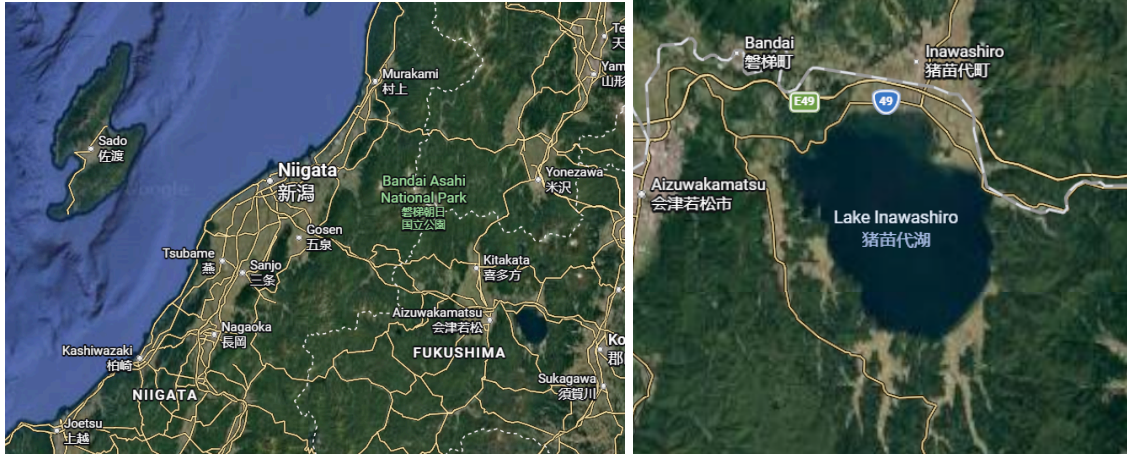
Sada je potrebno da pronađemo aerodrom koji je najbliži spomeniku - DCA.



Za odgovor na drugo pitanje je iskorišćena slika sa X naloga koja u sebi sadrži ime hotela. Pronalaskom hotela nađen je i aerodrom.



Jezero se pretražuje na mapi na osnovu treće slike na X nalogu.



Na osnovu rešenja zadatka 4, pronađeno je mesto koji napadač smatra domom - Hirosaki.

```

Anon, October 14, 2022 - 18:58

Saving here so I do not forget

School WiFi Computer Lab: GTRI-Device GTgfttt44221@
Mcdonalds: Buffalo-G-19D0-1 Macdonalds2020
School WiFi: GTvisitor GTFree123
City Free WiFi: HIROSAKI FREE Wi-Fi H Free934I
Home WiFi: DK1F-G Fsd1324T@@
  
```

What airport is closest to the location the attacker shared a photo from prior to getting on their flight?

DCA

✓ Correct Answer



What airport did the attacker have their last layover in?

HND

✓ Correct Answer



What lake can be seen in the map shared by the attacker as they were on their final flight home?

Lake Inawashiro

✓ Correct Answer

What city does the attacker likely consider "home"?

Hirosaki

✓ Correct Answer

